

INFORME DE AUDITORÍA Y EVALUACIÓN DE RIESGOS

FEVAL - Departamento de Informática



ISAAC ROMANILLOS DEZA

14/08/2026 - 04/09/2026

Prácticas de Ciberseguridad

INTRODUCCIÓN

Buenas, en este informe voy a documentar los resultados que he sacado del análisis y la evaluación de seguridad que le hicimos a los equipos conectados al segmento de red local 192.168.14.0/24. Básicamente el objetivo principal de esta auditoría ha sido mapear un poco la infraestructura lógica y física, ver qué superficie de exposición tenemos e identificar posibles ataques por culpa de usar software desactualizado o protocolos de comunicación y cifrados que ya no dan la talla.

ALCANCE DEL ANÁLISIS

Durante toda la auditoría nos pusimos a analizar 28 equipos operativos en total dentro de la subred plana 192.168.14.0/24. Este segmento tiene de todo un poco, desde servidores de la empresa y puestos de trabajo normales hasta sistemas biométricos y dispositivos IoT. Como no hay ningún tipo de segmentación de red usando VLANs, si te comprometen un equipo, el atacante lo tendría demasiado fácil para moverse lateralmente por toda la organización.

Nos hemos centrado más que nada en detectar:

- Sistemas operativos y servicios que ya están EOL, es decir, al final de su vida útil.
- El uso de protocolos de gestión que van en texto plano, tipo Telnet, HTTP o FTP.
- Servicios de acceso remoto que estan expuestos directamente (como el RDP y vpns súper obsoletas como PPTP).

MATERIAL

Para poder hacer el análisis en condiciones, he tirado de las siguientes herramientas:

- Nmap: Pues para descubrir hosts en la red, escanear puertos y sacar la huella digital de los SO y servicios.
- OpenVAS: Lo he usado bastante para detectar vulnerabilidades y evaluarlas cuantitativamente con un nivel de certeza (QoD) de más del 80%.
- WhatWeb: Para ver qué tecnologías web hay, los servidores subyacentes y echarle un ojo rápido al estado de las cabeceras de seguridad HTTP.
- Testssl.sh: Una herramienta de consola con la que le hemos dado un repaso a la robustez del cifrado SSL/TLS, si los certificados son válidos y si hay vulnerabilidades conocidas.
- Draw.io: Para dibujar el diagrama de la topología de la red.

PROCEDIMIENTO

El trabajo de campo siguió estos pasos:

1. Descubrimiento de red: Lanzamos escaneos pasivos y activos en el rango 192.168.14.0/24 para pillar todos los equipos encendidos y apuntar sus direcciones MAC.
2. Enumeración de Servicios: Identificamos qué puertos TCP/UDP estaban abiertos y sacamos los banners para saber las versiones exactas del software que corría en cada uno de ellos.
3. Extracción de Huella Digital: Sacamos los sistemas operativos y las plataformas de hardware de cada nodo.
4. Clasificación: Agrupamos todos los activos detectados dependiendo del rol principal que tenían en la red.
5. Mapeo Lógico: Montamos el diagrama de red poniendo el switch Ubiquiti como el nodo central.
6. Análisis Cualitativo: Fuimos evaluando los fallos basándonos en si faltaba cifrado, cómo estaba el ciclo de vida del software y si había demasiados servicios acumulados en los equipos clave.
7. Análisis de Vulnerabilidades: Por último hicimos un escaneo a fondo de los dispositivos activos para sacar métricas de severidad y auditar cómo estaba el cifrado tanto en las webs como en las VPN.

DATOS

1. Infraestructura de Red y Seguridad

- Fortinet FortiGate (192.168.14.254): Deja expuestos los puertos 22 (SSH), 80 (HTTP), 443 (HTTPS) y el 1723 (PPTP VPN).
- Switch Ubiquiti / Espressif (192.168.14.32): Este hace de conmutador principal de toda la instalación.
- Router Comtrend (192.168.14.201): Tiene expuestos el 21 (FTP), el 22 (con una versión viejísima de Dropbear SSH 0.36), el 23 (Telnet) y el 80 (HTTP).
- Dispositivo TP-Link (192.168.14.202): Un dispositivo Linux con el 80 (HTTP), 1900 (UPnP) y 49152 (HTTP auxiliar) abiertos.

2. Servidores y Almacenamiento

- Controlador de Dominio (192.168.14.53): Va con Windows Server 2012 R2. Muestra los servicios típicos (DNS por el 53, Kerberos en el 88, LDAP en el 389 y NetBIOS/MSRPC por el 135/139).
- Servidor Hyper-V (192.168.14.177): Está montado sobre Windows Server 2019. Tiene abierto RDP (3389), UltraVNC (5800/5900), HTTPS (443) y NetBIOS/MSRPC (135/139). Nos saltó una vulnerabilidad Alta en el puerto 443 porque usa protocolos de cifrado muy obsoletos.
- Servidor NFS en VM (192.168.14.36): Windows Server 2019 con el puerto NFS (111/2049), RDP (3389) y NetBIOS/MSRPC (135/139) activos.
- NAS WD MyCloud (192.168.14.50): Va sobre Linux y expone Pure-FTPd (21), HTTP (80), Samba (139), NFS v3 (2049), Python 3.9 (5357) y UPnP 1.8.4 (49152).

3. Dispositivos Especiales e IoT

- Terminal Biométrica (192.168.14.103): Corre un Kernel Linux 3.0.8 (MIPS ZMM220) y deja el puerto 23 (Telnet) expuesto al aire.
- Controlador IoT Atmel (192.168.14.180): Sistema Linux con OpenSSH 8.0 (22), HTTP (80) y HTTPS (443). Ojo con el 443 porque registra una vulnerabilidad Alta por usar suites de cifrado bastante débiles y protocolos que ya ni se usan.

4. Puestos de Trabajo

- Máquina virtual Windows 10 (192.168.14.54): Expone un servidor web de desarrollo (Werkzeug/Python 3.12.4 en el puerto 8000) y RDP (3389). Básicamente es el equipo que concentra el mayor riesgo de toda la subred, tiene 2 vulnerabilidades Críticas (puerto 3000) y 3 Altas (puerto 8000).
- Equipo ASUS Windows 10 (192.168.14.111): RDP (3389), RCP (135) y NetBIOS (139) abiertos.
- Equipos MSI Windows 10 (192.168.14.35, .52 y .97): Todos mantienen abierto el 21 corriendo una beta de FileZilla ftpd 0.9.60.
- Clientes RDP estándar (192.168.14.1, 2, 39, 40, 55 y .91): Solo exponen el puerto 3389 (RDP).
- Clientes seguros (192.168.14.12, 46, 51, 70, 76 y .126): Aquí no detectamos ningún puerto abierto en red.

5. Métrica Global de Vulnerabilidades:

- Vulnerabilidades Críticas: 3 hallazgos.
- Vulnerabilidades Altas: 5 hallazgos.
- Vulnerabilidades Medias: 67 Hallazgos.
- Vulnerabilidades Bajas: 25 Hallazgos.
- Total de eventos registrados (sin contar Logs): 100 Hallazgos.

6. Análisis de aplicaciones y servicios webs

- Servidor de Desarrollo Python (192.168.14.54): Ubicado en el puerto 8000, corre la app "Generación de Presupuestos" sobre Werkzeug/3.0.3 y Python 3.12.4. No tiene cabeceras de seguridad (ni CSP, ni HSTS, ni X-Frame-Options), nos lo pone fácil para ataques de ejecución remota o XSS.
- Router Comtrend (192.168.14.201): Su servidor "micro_httpd" pide autenticación sin cifrar (WWW-Authenticate: Basic), dejando las credenciales de administración al aire para cualquiera que intercepte el tráfico.
- Hyper-V (192.168.14.177): Usa "Microsoft-HTTPAPI/2.0" con "NTLM/Negotiate", un método super vulnerable a los típicos ataques de tipo desafío/respuesta.
- Controlador (192.168.14.180): Su panel "LORIX Manager" carece por completo de directivas HTTP seguras.
- TP-Link (192.168.14.202) y NAS MyCloud (192.168.14.50): Con WhatWeb confirmamos que operan en HTTP plano, sin cabeceras de bastionado ni redirección alguna.
- FortiGate (192.168.14.254): Este sí que presenta un buen nivel de bastionado, implementa correctamente Content-Security-Policy, HSTS (*max-age=63072000*), X-Frame-Options (*SAMEORIGIN*), y X-XSS-Protection (*1;mode=block*).

7. Auditoría Cifrado SSL/TLS

Evaluamos con `testssl.sh` los tres únicos equipos de toda la red que tenían servicios HTTPS expuestos:

- Servidor Hyper-V (192.168.14.177): Soporta versiones obsoletas (TLSv1.0 y TLSv1.1) y no te protege contra ataques de degradación. Como usa cifrado 3DES, es vulnerable a SWEET32 (CVE-2016-2183) y a BEAST (CVE-2011-3389). Además, el certificado está autofirmado, caducado desde el 2020, tiene errores en el nombre del host y el servidor permite a un atacante forzar cifrados débiles al no incluir la directiva "Server Cipher Order".
- Controlador IoT (192.168.14.180): Mezcla protocolos modernos (TLSv1.2 y v1.3) con obsoletos (v1.0 y v1.1). Al dejar los cifrados 3DES y CBC puestos, es vulnerable a SWEET32 y BEAST también. El certificado es autofirmado, caducó en 2021, incumple el RFC 7627/9325, no tiene campo SAN ni tampoco la directiva "Service Cipher Order".
- Firewall FortiGate (192.168.14.254): Aquí la postura de seguridad es sólida: te fuerza a usar TLSv1.2 y TLSv1.3, con una clave RSA robusta (4096 bits) y valida el host mediante SAN. Como áreas que habría que mejorar, presenta un periodo de validez mayor del recomendado (más de 398 días) y cifrado CBC que podría derivar en ataques tipo LUCKY13.

RESULTADOS

Una vez que juntamos y consolidamos todos los datos, confirmamos los riesgos que nos olíamos en la fase inicial e identificamos estas vulnerabilidades críticas:

- **Sistemas y software sin soporte:** El Controlador de Dominio (.53) está corriendo con Windows Server 2012 R2 y SQL Server 2012, que son productos sin parches de seguridad a día de hoy. Esto ha provocado que salte 1 vulnerabilidad Crítica en el puerto 1433. A nivel de usuario, encontramos software en fase beta (FileZilla 0.9.60) y servicios SSH muy antiguos (Dropbear 0.36 en el equipo 201), propensos a caídas de servicio y ejecución de código.
- **Uso de Protocolos Inseguros:** Las credenciales y datos viajan en texto plano continuamente por culpa de usar Telnet (equipos 103 y 201), FTP estándar (equipos .35, 50, 52, .97 y .201) y gestores web sin TLS (equipos 50, 201, .202 y .254).
- **Canales VPN Obsoletos:** El firewall (.254) permite conectarse a través del puerto 1723 (PPTP), un protocolo altamente vulnerable a que te rompan el cifrado MS_CHAPv2.
- **Superficie de Ataque Innecesaria:** El acceso remoto RDP (3389) está expuesto de forma masiva. Preocupa sobre todo la máquina de desarrollo Python (.54) accesible en red, la cual introduce 2 vulnerabilidades Críticas y 3 Altas ella sola.
- **Cifrado HTTPS deficiente:** Los equipos 177 y 180 mantienen vulnerabilidades Altas por soportar los estándares deprecados TLSv1.0 y TLSv1.1.
- **Falta de bastionado web:** WhatWeb nos facilitó que no hay casi directivas de seguridad tipo CSP, HSTS o X-Frame-Options en el entorno de desarrollo (.54) ni en el panel del IoT (.180), a parte de lo que ya comentamos de enviar claves en claro en el equipo .201.
- **Métrica global (sobre las 28 direcciones IP evaluadas):** Pillamos un total de 100 vulnerabilidades puras (3 Críticas, 5 Altas, 67 Medias y 25 bajas), sumadas a 698 eventos informativos relacionados sobre todo con el protocolo MSRPC y respuestas TCP Timestamps.

CONCLUSIÓN

Resumiendo, la infraestructura actual de la subred 192.168.14.0/24 tiene un nivel de riesgo excesivo. Esto viene provocado sobre todo por la falta de segmentación, la ausencia total de cifrado en algunas partes y el uso de sistemas que ya están pasados de fecha de fin de vida. Para intentar solucionar estas deficiencias estructurales, propongo aplicar el siguiente plan de mitigación dividido en tres fases:

1. Acciones Inmediatas:

- Aislar de la red y arreglar los servicios web (puertos 3000 y 8000) alojados en la IP 192.168.14.54.
- Meterle los parches críticos a la instancia MS-SQL en el equipo 192.168.14.53.
- Obligar a usar TLSv1.2 o superior en las direcciones 192.168.14.177 y .180, quitando ya definitivamente TLSv1.0 y TLSv1.1.
- Cerrar los canales que van en texto plano en el firewall (Telnet, FTP normal) y la VPN por PPTP. Hay que sustituirlos por opciones seguras como SSH, SFTP y túneles SSL/IPsec.
- Cambiar los certificados autofirmados y caducados de los equipos .177 y .180 por unos nuevos que expida una CA interna de confianza, asegurándonos de que el campo SAN está bien configurado.
- Cortar de raíz la autenticación HTTP en claro en la IP 192.168.14.201 para que no roben las credenciales administrativas.

2. Fase a Corto Plazo:

- Desplegar políticas de grupo (GPO) para limitar quién puede entrar por RDP y no dejar que instalen betas ni servidores de desarrollo sin control.
- Sanear un poco las suites de cifrado en las direcciones .177, .180 y .254 desactivando los cifrados de 64 bits (3DES) y los modos CBC. Con esto mitigamos los ataques SWEET32, BEAST y LUCKY13. A cambio, hay que exigir el uso de algoritmos modernos AEAD (como AES-GCM) junto a Forward Secrecy (ECDHE).

- Poner cabeceras HTTP de seguridad (Content-Security-Policy, HSTS, X-Frame-Options) en los servidores de los equipos .54 y .180 para evitar ataques tipo Clickjacking o XSS.
- Arreglar la cadena de confianza del FortiGate (.254) instalando el certificado intermedio que falta y limitando la vida útil de sus claves a un máximo de 398 días.

3. Fase a Medio Plazo:

- Aislar la red lógicamente metiendo VLANs independientes en el Switch Ubiquiti. Es clave separar en segmentos aislados la parte de servidores, la de ofimática de usuarios y los dispositivos IoT.
- Ponerse a planear la migración del Controlador de Dominio a Windows Server 2022.
- Montar un servidor de certificados PKI corporativo que soporte OCSP o CRL de forma activa. Esto nos dejará gestionar y revocar certificados de todos los servidores y dispositivos IoT de manera automática y segura.